

Análisis de Seguridad y Validación de Vulnerabilidades con DVWA

Escenario Simulado

Entorno controlado con DVWA (Damn Vulnerable Web Application) accesible en:
<http://192.168.1.3:8080/login.php>

Paso 1: Reconocimiento y Mapeo Inicial

- ♦ **Comando:** `whois 192.168.1.3`

Propósito: Identificar información de registro del propietario de la IP.

Resultado: Al ser una IP privada (RFC1918), `whois` devuelve que pertenece al bloque reservado de IANA.

Interpretación: No se puede identificar un propietario real; es válida solo para redes internas.

- ♦ **Comando:** `nslookup 192.168.1.3`

Propósito: Resolver la IP hacia un nombre de dominio.

Resultado:

Server: 10.0.2.3

Address: 10.0.2.3#53

3.1.168.192.in-addr.arpa name = blandskron-Iris.

Interpretación: La IP tiene un nombre local `blandskron-Iris`, lo que indica una máquina en red privada.

♦ **Comando:** `dig -x 192.168.1.3`

Propósito: Resolución DNS inversa (PTR).

Resultado:

3.1.168.192.in-addr.arpa. IN PTR blandskron-iris.local.

Interpretación: Similar a `nslookup`, resuelve el nombre de la máquina desde la IP. Útil en red interna.

Paso 2: Escaneo de Puertos y Servicios

♦ **Comando:** `nmap -sS -sV -T4 -p- 192.168.1.3`

Propósito: Realizar escaneo de todos los puertos TCP con detección de versiones de servicios.

Resultado completo:

PORT	STATE	SERVICE	VERSION
3000/tcp	open	ppp?	OWASP Juice Shop
7070/tcp	open	ssl/realserver?	(desconocido)
8080/tcp	open	http	Apache httpd 2.4.25 (Debian)
8081/tcp	open	http	Apache httpd 2.4.7 (Ubuntu)
8082/tcp	open	http	Apache httpd 2.4.7 (Ubuntu)
8083/tcp	open	http	Apache Tomcat
9000/tcp	open	http	Gophish

Interpretación: Apache y Juice Shop expuestos. Múltiples servicios escuchando en puertos no estándar.

Paso 3: Pruebas de SQL Injection con SQLMap

♦ Comando 1:

```
sqlmap -u "http://192.168.1.3:8080/vulnerabilities/sqli/?id=1&Submit=Submit" \
--cookie="PHPSESSID=abcdef1234567890; security=low" --dbs
```

Propósito: Detectar SQLi en el parámetro `id`.

Resultado: SQLMap reporta que no encuentra parámetros inyectables.

Interpretación: Puede requerirse elevar el nivel de prueba o usar evasores.

♦ Comando 2 (repetición con otra sesión):

```
sqlmap -u "http://192.168.1.3:8080/vulnerabilities/sqli/?id=1&Submit=Submit" \
--cookie="PHPSESSID=xyz123; security=low" --dbs
```

Resultado: Mismos resultados. Se sugiere usar:

```
--risk=3 --level=5 --tamper=space2comment --random-agent
```

Interpretación: DVWA puede requerir condiciones específicas para que `sqlmap` detecte la vulnerabilidad.

Paso 4: Nikto – Auditoría Web

♦ Comando:

```
nikto -h http://192.168.1.3:8080
```

Propósito: Detectar configuraciones inseguras en el servidor web.

Hallazgos:

- Falta de cabeceras de seguridad (`X-Frame-Options`, `X-Content-Type-Options`)
- Cookies sin `httponly`

- Directorios públicos como `/config/`, `/docs/`
- Archivo `.gitignore` accesible
Interpretación: Existe exposición innecesaria, lo que representa riesgo de reconocimiento o explotación.

